

Security Policy Drafts

Password & Authentication | Acceptable Use | Data Handling & Classification

Policy 1 - Password & Authentication

- **Purpose:** Reduce unauthorized access by establishing secure authentication requirements.
- **Scope:** Employees, contractors, service accounts, administrators, and systems supporting business operations.
- **Requirements:** Use unique credentials; prohibit credential sharing; require MFA for privileged and remote access; use approved password managers; disable default credentials; promptly revoke terminated-user access; rotate secrets when compromise is suspected.
- **Privileged access:** Separate administrative accounts from daily-use accounts; review privileges quarterly; log privileged actions; use time-limited elevation where supported.
- **Exceptions:** Document business need, owner, compensating controls, approval, and expiration date.

Policy 2 - Acceptable Use

- Company systems are primarily for authorized business activity and must not be used to bypass security controls, run unauthorized tools, or access prohibited content.
- Users must protect devices from unauthorized access, report suspected phishing/malware, and avoid transferring company data to unapproved services or personal accounts.
- Software installation requires approved processes; removable media is restricted according to business need and endpoint controls.
- Security monitoring may be performed to protect company assets, investigate incidents, and meet legal or regulatory obligations.

Policy 3 - Data Handling & Classification

Class	Examples	Handling requirements
Public	Approved marketing content	May be shared publicly after normal approval.
Internal	Internal procedures, non-public operational data	Approved company systems; access based on business need.
Confidential	Customer records, contracts, internal financial data	Least privilege; encryption in transit/at rest; approved sharing; retention rules.
Restricted	Authentication secrets, regulated or highly sensitive data	Strict need-to-know; strong encryption; enhanced logging; controlled export; approved storage only.

Enforcement, Review, and Exceptions

- Violations may result in access restriction, corrective action, investigation, or other action consistent with company policy and law.
- Policy owners review these policies at least annually and after major incidents, regulatory changes, or material technology changes.
- Exceptions are time-bound, approved by the appropriate risk owner, and tracked until expiration or remediation.
- Security and GRC maintain evidence of acknowledgement, reviews, exceptions, and material policy changes.

Control Alignment

- NIST CSF 2.0 Protect themes: identity management, data security, platform security, and awareness.
- NIST SP 800-53 examples: AC (Access Control), IA (Identification and Authentication), PL (Planning), PS (Personnel Security), SC (System and Communications Protection).
- ISO/IEC 27001 alignment: access control, information classification, acceptable use, authentication information, and information transfer themes.